OutOfRole Team Guide

The Debugging Table · IBM Z Datathon 2026 · What we built, what the data shows, and answers to common questions

Contents

The project in one minute 1

The data we test on 2

What we built, part by part 2

The baseline: what we compare against 3

Results, backed by data 4

How we got here: the main improvements 5

How we know the results are real 5

Is it practical for a real company? 6

Keeping it relevant as people and roles change 6

How we use the LLM (Granite) 6

How it connects to our proposal 7

What we say openly 7

Who builds what at the event 7

Questions you may have 8

Glossary 9

Where to find everything 9

The project in one minute

Some employees misuse access they legitimately have. They copy files to a USB stick before quitting, upload documents to a leak site, or log into colleagues' computers to snoop. Their logins are valid, so simple rules either miss them or bury analysts in alerts.

OutOfRole helps a security team catch these people while they are still active:

- **Watch.** Every day, it compares each employee's last week with their own normal weeks. The 20 most unusual people form that day's review list.
- **Snooping review.** A Netflix-style recommender learns which computers each person normally uses. A periodic review flags people who keep logging into computers outside their profile.

- **Explain.** For each flagged person, code ranks the evidence. IBM Granite picks a label and the supporting facts, and code writes every sentence, so the AI cannot make things up.
- **Advise on access.** The recommender predicts which websites each person will use next, so routine access can be pre-approved, and websites people stopped using become access-review suggestions.

Everything runs on one IBM LinuxONE server, and people appear only as pseudonyms (U-017).

Headline: in a day-by-day replay of 2,000 employees' logs, our 20-name daily list caught **80 of 99 insiders while they were still active**, twice the 40 caught by a standard baseline with the same 20-name list. The baseline is explained in its own section below.

The data we test on

We use the **CERT Insider Threat dataset** from Carnegie Mellon, the standard benchmark for this problem. It is synthetic: generated logs of a fake company, with a separate answer key listing who the insiders are and what they did.

Release	Staff	Insiders	Months of logs
r4.2	1,000	70	about 17
r5.2	2,000	99	about 17

The logs cover logons (when, which computer), USB use, file copies, web browsing and email. The insiders follow four attack patterns:

Attack type	What they do	In
Leakers	Start working after hours, use USB sticks, upload data to wikileaks.org	both
Job-hunters	Browse job sites, then copy data to USB at a higher rate than before, then leave	both
Disgruntled sysadmins	Download a keylogger, plant it on a supervisor's computer, use the stolen login	both
Snoopers	Log into colleagues' computers, search for files, email them home, more and more often	r5.2 only

How we use it. The early months are "training": we learn what normal looks like for each person. Then we replay the later months one day at a time, as if live, and only use the past on each day. The answer key is used only to grade the results, never to build or tune the detector. We fixed every setting on r4.2, then ran r5.2 unchanged, so r5.2 is the fairer test.

What we built, part by part

1. The daily review list (the main detector)

For each person and each day, we take their last 7 days of activity: logons, after-hours logons, USB use, after-hours USB use, file copies, after-hours file copies, web browsing, after-hours browsing, and the number of computers used. We compare each count with **every one of that person's normal weeks** from training. If this week is higher than all of them, that activity counts as unusual. The person's score is the number of unusual activities. Scores build up over a week, so persistent oddness rises and a one-off spike fades. The 20 highest scores form the day's list.

2. The snooping review (the recommender's detection job)

The recommender (an ALS model, the same kind of collaborative filtering Netflix-style systems use) learns which computers each person normally logs into. A login to a computer that is new to the person and that the recommender

scores as unlikely for them is flagged. The review counts the weeks with such logins and discounts people who always move between computers anyway, such as IT staff.

3. The case file (where Granite comes in)

For each flagged person, code ranks what they did: things not seen in their training history first, then the rarest in the company. The top items become an evidence pack, with an ID for each fact (E1, E2, …). Granite replies with only two things: a label from a fixed list ("possible data theft", "possible data leak", "possible snooping", "unusual after-hours activity", "weak evidence") and the IDs of the supporting facts. Code writes every sentence from the evidence pack and always shows the top 3 items. Any other reply is rejected and replaced by a fixed fallback. That is how we guarantee the AI cannot invent a fact.

4. Access advice (the recommender's second job)

The same kind of recommender learns which websites each person uses and predicts which new ones they will use next. Those can be pre-approved, so reviewers see fewer routine requests. Websites a person used in training but not since become suggestions for removing access.

5. New-site rule

Visits to websites no one in the company had used during training are flagged. In CERT, this catches every wikileaks and keylogger-site visit. For a real company, the practical version is to hold **uploads** to never-seen or newly registered sites, not to block browsing (see "Is it practical?").

The baseline: what we compare against

What it is. The standard "is this person acting unusually compared with their own habits?" check that a basic monitoring tool would run. We call it the 28-day personal baseline.

How it works. For each person, take the last 28 days and count five things: USB use, file copies, after-hours logins, after-hours USB use and after-hours web browsing. Compare each count with what that person's own training-period habits predict for 28 days. The bigger the excess, the higher the score. The 20 highest scores form its daily list.

How we measure both. We replay the test months day by day with only past data. Both methods get the same 20-name daily list. An insider counts as **caught in time** if they appear on the list at least once between their first and last malicious action. We also compare against chance (random lists), which catches about 3 insiders.

What we do differently to beat it.

1. "Higher than every normal week" instead of "higher than average": averages are thrown off by people who are naturally bursty.
2. More signals, including the number of computers used, which is how snooping shows up.
3. A score that builds up over a week, so persistent behaviour stands out.

Where each one wins (insiders caught in time, r4.2 / r5.2):

Attack type	Our daily list	Baseline
Leakers	25/30 / 26/29	25/30 / 23/29
Job-hunters	**30/30 / 27/30**	25/30 / 7/30
Snoopers (r5.2 only)	**25/30**	2/30
Disgruntled sysadmins	4/10 / 2/10	**9/10 / 8/10**
All insiders	**59/70 / 80/99**	59/70 / 40/99

That is why r5.2 shows twice the catches (it has snoopers and harder job-hunters) while r4.2 ties. The baseline is clearly better on the two-day sysadmin sabotage.

Results, backed by data

All numbers below come from one program, `feasibility/reference/outofrole_minimal.py`, and are listed with their sources in `feasibility/Verified_Numbers.md`.

Catching insiders in time

Result	r4.2	r5.2
Insiders on our daily list before their last malicious action	59 of 70	**80 of 99**
Same, 28-day baseline with the same 20-name list	59	40
Same, random score with the same list size	10	11
Average share of each insider's malicious actions that come after we flag them	54%	48%

Do insiders just appear, or appear more often?

Much more often. This matters: if innocent people appeared as often, the list would be useless.

On a given day	r4.2	r5.2
A normal employee is on our list	1.3% of days	0.7% of days
An insider, during their attack, is on our list	82% of days	54% of days
So an active insider is on the list	**64x as often**	**82x as often**
Same comparison for the baseline	39x	47x
Insiders' share of list slots (their share of staff)	40% (7%)	37% (5%)

The honest trade-off: over a whole year, 25% (r4.2) and 15% (r5.2) of normal staff appear on our list at least once, usually briefly (median 9 to 10 days in the whole year). The baseline puts fewer different people on its list but keeps them there about twice as long.

Evidence for the case files (before Granite)

Result	r4.2	r5.2
Insiders caught in time whose top 3 evidence items include a real malicious action	64%	85%
Same, ranking by rarity alone	49%	51%
"Strong evidence" at first alert: insiders vs normal staff (no labels used)	29% vs 18%	65% vs 31%

The recommender

Result	r4.2	r5.2
Next new websites caught by its top 20 guesses (popularity in brackets)	21% (14.5%)	19% (13%)

Result	r4.2	r5.2
Access requests per person per month: history only, then with the recommender	2.31 to 1.82	3.15 to 2.55
Same, retrained monthly with approvals kept: history only / trained once / retrained monthly	2.24 / 1.76 / 1.61	3.08 / 2.50 / 2.21
Websites used in training but not again (access-review suggestions)	6.0%	3.6%
Snooping review: snoopers in its top 100 (without the recommender)	no snoopers	27 of 30 (26)
Same review as a live 10-name daily list: snoopers caught in time	no snoopers	9 of 30
Wikileaks and keylogger-site visits caught by the new-site rule	100%	100%

How we got here: the main improvements

We tested about 20 ideas in order. Each one either earned its place or was dropped with evidence.

Step	What we tried	Before	After	Verdict
Baseline	28-day personal baseline	(none)	44 / 39 insiders in the top 100 reviewed people	the bar to beat
Trained models	Learn from labelled insiders	39 found	45 to 60 found	dropped: with an attack type hidden from training they found only 4 to 7 of 30 job-hunters
Label-free scoring	No labels at all	trained: 4 to 7	16 of 30 hidden job-hunters	kept
Own-history percentile	"Higher than every normal week"	18 of top 20 real insiders (r5.2)	20 of 20 on both releases	core of the daily list
Combined signals	Fuse several label-free signals	44 / 39 in the top 100	55 / 43	kept as a comparison
Recommender as detector	Flag surprising websites	popularity	no gain on any item type	moved to other jobs
Recommender tuned properly	Settings chosen without labels	popularity 14.5%	21.1% next-site recall	real job: access advice
Learning from analyst verdicts	Re-weight after each review round	55 / 43	57 / 42	dropped: noise
Day-by-day replay	The daily list	baseline 59 / 40 caught in time	59 / 80	the headline
Evidence ranking	"New to you, rarest first"	rarity 49% / 51%	64% / 85%	used for case files
Recommender snooping review	Computers outside the profile	any new computer: 26 of 30	27 of 30	kept as a periodic review

How we know the results are real

- **Strict time split.** Training months come first, then the replay, and on each day only the past is used.
- **Labels only for grading.** No setting was fitted to the answer key.
- **Frozen settings.** Everything was fixed on r4.2, then run unchanged on r5.2.
- **Unseen attacks.** Hiding an attack type from trained models showed they overfit (4 to 7 of 30), which is why the final system uses no labels.

- **Resampling.** Over 5,000 resamples of the insiders, our lead on r5.2 stays between +27 and +52 and is never zero or negative. On r4.2 it is a genuine tie (-6 to +6).
- **Controls.** A random score with the same list size catches 10 and 11. Moving the training cutoff a month later changes nothing.
- **Independent checking.** A separate validator re-ran every script and found no use of future data or answer-key leakage. One mislabelled number was corrected.
- **Outside review.** Codex reviewed the work in 11 rounds; its final verdict on simple, impressive and connected to the proposal was "yes" on all three.
- **Reproducible.** One 253-line program rebuilds every headline number in about 20 seconds per release.

What remains a risk: a few choices were made after seeing results (the daily-list method, the snooping review, the training cutoff date). The fix is a dataset we have never looked at, which is why we are adding the LANL dataset (see the FAQ).

Is it practical for a real company?

Part	Practical?	How to present it
Daily list and case files	Yes. This is how commercial insider-risk tools work (Microsoft Purview Insider Risk, Sentinel UEBA).	A triage aid for analysts, not an accusation tool. In a real company insiders are far rarer than CERT's 5 to 7%, so most names will be innocent.
Snooping review	Yes, as a monthly report.	"Who keeps logging into computers outside their role?"
Case files with Granite	Yes. The constrained design suits compliance and audits.	Granite labels and picks facts; code writes the text.
Access advice	Yes, but for applications, shared drives and groups. Companies do not manage website access per person.	An access-review assistant. CERT has no permission lists, so websites stand in.
New-site rule	Not as built: blocking every never-seen site is excessive. It only works because CERT has about 470 websites in total.	Hold or flag uploads to never-seen or newly registered sites.

Keeping it relevant as people and roles change

- **CERT never changes anyone's role** (0 role changes), though 14 to 30 people change department and 126 to 213 change team. So we tested the general fix: let each person's "normal" roll forward, using their last 26 weeks and skipping the most recent 4 so a slow attack cannot become the new normal.
- **Detection held:** 59 of 70 and 84 of 99, against 59 and 80 with frozen normal weeks. The cost is that more innocent people appear on the list at some point (274 vs 230, and 374 vs 291).
- **Retrain the recommender monthly.** It trains in seconds. Monthly retraining cuts access requests 28% below own history alone, against about 21% when trained once.
- **For a real deployment:**
  - update each person's normal weekly
  - when HR records a role or department change, compare the person with their new team for a few weeks and note the change in the case file
  - keep confirmed incidents out of anyone's "normal"
  - retrain the recommender monthly

How we use the LLM (Granite)

Now: Granite labels each case and chooses the supporting facts from the evidence pack; code writes every sentence and rejects anything else. A self-test sends 12 bad replies (made-up names and quantities, unknown facts, broken

JSON) and all of them fall back safely.

Planned for the event, in order of value:

1. **Measure its labels.** Compare Granite's attack-type label with the answer key; chance is 1 in 4 on r5.2. This turns "AI explains" into a measured number.
2. **Daily briefing.** Granite summarizes the day's list (who is new, who escalated, which pattern), using the same labels-and-IDs approach.
3. **"Ask your logs."** An analyst types a question in plain English; Granite picks one of a fixed set of queries and fills in the details; code runs it. A strong live demo on LinuxONE.
4. **Access-review notes.** Granite drafts the reason behind each removal or pre-approval suggestion from the facts.

How it connects to our proposal

We promised	We deliver
"A recommender that catches insider snooping" (our title)	The recommender's snooping review finds 27 of 30 snoopers; live, the daily list catches 25 of 30 in time
"Learns which files and machines each employee normally uses"	Computers and websites. File identities were not modelled: 100% (r4.2) and 94% (r5.2) of CERT file names belong to one person, which leaves nothing to learn
"Access it would never suggest is flagged"	Snooping review for computers; pre-approval and review for websites
"An AI on the same server explains why"	Granite case files on LinuxONE
Analysts, compliance officers, access admins	Daily list; dated, cited case files; access suggestions
Data never leaves the platform	One server, pseudonyms only
Spark, ALS on early months, later months replayed live	Exactly that

What changed: each person's own history catches insiders better than the recommender does, so it drives the broad daily list. The recommender does two jobs where it measurably helps: the snooping review and access advice.

What we say openly

- CERT is synthetic data; these are replay results, not a live deployment.
- The daily-list method was chosen after seeing results. The method we had named in advance also beat the baseline (54 vs 28 of 99).
- Two-day sysadmin sabotage is mostly missed; the baseline does better there.
- The snooping review was designed after looking at r5.2; as a live list it catches only 9 of 30 snoopers in time.
- Most leakers were already doing suspicious USB copying before the answer key's start date, so "caught the same day" partly means "already on the list".
- Granite and the LinuxONE run are built at the event; the code they plug into is tested here.

Who builds what at the event

Full detail, hour by hour, is in `Build_Plan.pdf`.

Role	Builds
R1, data and platform	VM setup (Java 17, PySpark, Docker), download CERT, Spark builds the three tables, container and repo
R2, detection	Port the daily list from `outofrole_minimal.py`, run r4.2 then r5.2, results table

Role	Builds
R3, Granite	Both IBM labs, then port `case_file.py`: evidence pack, Granite prompt, reply check, fallback
R4, recommender and demo	Port the recommender parts (snooping review, access advice, new-site rule), dashboard, video

Freeze the detector settings by hour 12. If something is behind, the build plan's cut rules say what to drop.

Questions you may have

What exactly is "in time"? The insider appears on the daily list at least once between their first and last malicious action, so there is still something to stop.

If innocent people appear on the list too, did we achieve anything? Yes. On a given day, an insider in the middle of an attack is 64 to 82 times as likely to be on the list as a normal employee. Insiders hold 37 to 40% of list slots while being 5 to 7% of staff; a random list would give them 5 to 7%.

Why not just use the baseline? On r5.2 it catches 40 insiders in time against our 80, and misses almost all snoopers (2 of 30) and most job-hunters (7 of 30). It is better on sysadmins, which suggests combining the two lists; we have not tested that yet.

Why did the recommender stop being the main detector? We tested it on websites, computers, website-by-hour, email recipients and browsing order. It never beat simple popularity at spotting insiders, because most attacks either use sites nobody visits (popularity already catches those) or sites that look normal for the person. It is genuinely better at predicting what people will use next, so it moved to access advice and the snooping review.

Can Granite invent facts in a case file? No. Granite returns only a label from a fixed list and fact IDs. Code writes every sentence from the evidence pack. Any other reply is rejected and replaced by a fixed fallback; the self-test proves this with 12 bad replies.

What if Granite does not work at the event? The fallback case file is fully deterministic and still shows the ranked evidence. The demo works without Granite; Granite adds the label.

Did we overfit? We guarded against it at every step (see "How we know the results are real"). The remaining risk is choices made after seeing results; the LANL test addresses it.

What is the LANL dataset, and why add it? Los Alamos National Laboratory published 58 days of real (not synthetic) login records from its network: 12,425 users, about 1 billion login events, plus a list of 749 red-team attack logins. Using it tests our ideas on data we have never seen. Its attacks are outside intruders moving between computers with stolen accounts, so the snooping review (logins outside a person's normal computers) is the closest fit. We requested the data and are downloading it now.

Do we need to retrain when roles change? Yes, cheaply: roll each person's normal forward weekly, treat a role change as a reason to compare with the new team for a few weeks, and retrain the recommender monthly. Our tests show detection holds with a rolling normal and monthly retraining cuts more requests.

Is it impressive? On r5.2, yes: twice the baseline, robust to resampling, with 54 to 48% of each insider's malicious actions still ahead when we flag them. On r4.2 it ties the baseline. The rigor is our main differentiator: independent validation, 11 review rounds, and one short program that reproduces everything.

Why 20 names a day? A small team can review 20 people a day. It also makes the comparison fair, since every method gets the same list size.

How much code is the build? Two files: 253 lines for scoring and 85 lines for case files, on top of the three tables Spark builds. About 20 seconds per release on a laptop.

What runs on LinuxONE? Everything: Spark builds the tables, Python scores and ranks, Granite labels the case files, and the dashboard shows the list. Nothing leaves the server.

What should I say to judges in one sentence? "In a day-by-day replay of 2,000 employees' logs, OutOfRole put 80 of 99 insiders on a 20-name daily review list while their attacks were under way, twice a standard baseline; Granite labels each case from checked evidence; and a recommender handles snooping reviews and access advice."

Glossary

- **Insider:** an employee who misuses legitimate access.
- **Baseline:** the simple standard method we must beat (here, the 28-day personal check).
- **Caught in time:** listed before the insider's last malicious action.
- **Recommender / ALS:** a model that learns "people like you use these things", as in Netflix recommendations.
- **Popularity:** the simplest recommender: guess what most people use.
- **Evidence pack:** the top-ranked facts for one person, each with an ID.
- **Fail closed:** when a check fails, show the safe fallback instead of the risky output.
- **Synthetic data:** generated data that imitates real logs; it has an answer key.
- **Overfitting:** a method that looks good on the data it was tuned on but fails on new data.

Where to find everything

- `OutOfRole_In_Plain_Words.pdf`: the three-page summary.
- `Build_Plan.pdf`: who builds what, hour by hour, and the cut rules.
- `feasibility/Verified_Numbers.md`: every number with the script that produced it.
- `feasibility/reference/outofrole_minimal.py` and `case_file.py`: the code to port.
- `feasibility/OutOfRole_Feasibility.ipynb`: the full study with code and explanations.
- `feasibility/codex_review/`: all 11 review rounds.